TEMASEK POLYTECHNIC
SCHOOL OF INFORMATICS & IT
DIPLOMA IN CYBERSECURTY & DIGITAL FORENSICS

AY 2020/2021 OCTOBER SEMESTER TERM A
SECURE WEB APPLICATIONS
CASE STUDY

SECURE WEB APPLICATIONS (CCD2C08)
SUBJECT LEVEL: 2

INSTRUCTIONS TO CANDIDATES

1. This paper consists of 7 pages (including cover page).

2. This document describes the case study that should be submited for secure web applications.

3. This case study contributes ***70%*** of the subject.

4. Please complete this case study in groups of 4 - 5 members.

5. Please read the requirements of the case study and follow the submission instructions carefully.

Case Study
This document describes the case study for SWAP. *Please read this document carefully and follow the submission instructions.*

Learning Objectives

1. Propose, plan, design, develop and test software applications
2. Experience a project development cycle and its challenges
3. Learn software vulnerabilities and propose ways & methods to secure applications against vulnerabilities
4. Document application requirements, plans, codes and test results
5. Review/comment completed work and propose future enhancements
6. Work collaboratively in a team. **Form teams as instructed by the tutor**

Pre-requisites

Please complete and submit the practical lab activities highlighted by tutors and learn how to use the development tools. ***Please note that submitted labs contribute a total of 5% under phase 2 and phase 3 of the case study****. The team should know how to document system requirements and build web applications. In addition, the team should know the common web vulnerabilities of web applications.*

Project Scope

In this project, the team proposes and develops a **PHP secure web application** that would manage information in a database. Aside from the technical areas, the application will be evaluated on the effectiveness of addressing real-world problems. In the proposal, define the problem area clearly and describe the solution with targeted users having different roles.

The scope of work for the project must include *but not limited to* the following:

- At least 1 database table containing user *login & role* information.
- At least 1 database table containing some *sensitive* information (not including user information)
- Functionalities that create, read, update and delete (CRUD) information from 1 table in the database in a secure manner
- At least 2 views to cater for user of different roles to perform various functions(e.g. *only administrator is able to delete data)*
- At least 5 misuse cases
- Secure login function
- Secure communications between client & server
- Robust codes against common web vulnerabilities
- Data stored persistently in the database

Project should be implemented with libraries and software indicated below:

- Libraries from the lab exercises
- Eclipse-based Package for PHP Developers or any compatible Integrated Development Environment (IDE)
- XAMPP or any compatible platform
- MySQL or MariaDB or any compatible databases
- Microsoft Visio or any compatible software for UML
- *Seek tutor's permission* via email before using any 3rd party software (i.e. not mentioned in subject materials or used in lab exercises)

Requirements

A software development project can be categorized into the following Software Development Life Cycle (SDLC) phases:

- Project Initiation
- Requirements Gathering
- Analysis
- Design
- Develop & Test
- Deploy & Maintenance

Below is a guide on the tasks in each phase of the project and the associated deliverables:

Deliverables

Case Study (Total 70%)

1. **Phase 1: Project Initiation & Requirements Gathering Phase *[Group (10%)]***

   The team is required to **propose** and **plan** a secure web application project that would manage information in a database. The team is required to analyze the project and document the requirements with use case diagrams. The team should distribute and delegate the work to each member at the beginning phase of the project to minimize the conflicts during the SDLC.

   1. Confirm the project team
   2. Describe the problem statement and propose a web application solution to address the problem
   3. Plan how the team is going to deliver the project and include activities and milesontes in a Gantt chart.
   4. Develop use case diagram for the project *(Note: This use case diagram specifies the functional requirement of the project.)*
   5. Perform threat modelling and specify misuse cases in the use case diagram *(i.e. How the application can be misused?)*
   6. Define the non-functional requirement for the project and explain how each requirement will be achieved
   7. Design the test plan indicating the timeline and types of testing, include test activities in the Gantt chart. *(i.e. How to ensure that the application is functioning correctly?)*
   8. Distribute the workload evenly among the team *(i.e. Distribute the use cases, coding, testing and documentations evenly between the team members)*

   Deliverables: To be submitted during Proposal Submission

Deliverables (individual)	Deliverables (group)
1. Nil	1. Submit an interim report *(10%)* (Refer to template *P0xGpx_NAME_SWAP_ReportTemplate.docx)*

   Date of submission: Please refer to teaching plan

2. **Phase 2: Application Analysis and Design Phase *[Individual (10%)]***

   Each team need to **analyse the requirements and design a simple working prototype** implemented in PHP. The prototype need not be full functional but should at least demonstrate the flow of the application. Individual members are required to analyse their assigned use cases, identify potential threats/risks and discuss possible mitigation controls for their modules for the application. Please clarify any doubts and risks of the project in the early phases. Each member is required to discuss create, read, update and delete (CRUD) functions of their assigned use cases from the use case diagram. Please ensure that application data are stored in the database. Please prepare presentation slides to discuss the above-mentioned areas in Phase 1 and Phase 2.

Deliverables: To be submitted during Proposal Submission

Deliverables (Individual)	Deliverables (Group)
1. Basic coding (e.g. PHP, HTML, CSS, JavaScript, etc.) (assessed based on good programming practice and explanation)	1. Nil
2. Basic prototype (assessed on functionality, user friendliness and security features)	2. Nil
3. Discussions on risks/threats and possible mitigations	3. Nil

Date of submission: Please refer to teaching plan

3. **Phase 3: Application Development, Testing and Integration + Website Penetration Test *[Individual (40%)]***

i) <u>Development, Integration and Testing</u>

Each team need to **develop, test and integrate** the working website implemented in PHP. Develop test cases for each individual function/component (known as ***Unit Testing***). Automatic testing tool (e.g. PHPUnit) should be used for unit testing. Integrate components from different team members and conduct **Integration Testing**. Next, the team needs to conduct **System Testing** on the completed system to verify the system design. Automatic testing tool may be used for different types of testing. Lastly, the team conducts **Acceptance test** to check that implemented applications fulfill the requirements.

ii) <u>Website Penetration Testing</u>

The team is required to conduct **Penetration Test** on given websites provided by the tutor. The websites are deliberately vulnerable and each member of the team must conduct tests based on **OWASP 2017 Top 10 Web Application Vulnerabilities**. https://www.owasp.org/index.php/Top_10-2017_Top_10.

The objective is to undercover security vulnerabilities in websites. Please provide at least 10 security vulnerabilities and discover as many vulnerabilities as possible.

- Each member performs penetration tests on the given vulnerable website to uncover at least 2 security vulnerabilities (preferably at least 1 from each website).

- For each security vulnerability, describe the tools used and necessary test procedures to demonstrate the vulnerability. Focus on explaining the risk and impact of the vulnerability. Thereafter, propose and justify possible remediation.

- Please focus on the security aspects of vulnerabilities (i.e. risks, threats, impacts and controls). Each test result will be evaluated based on the difficulty level and the explanation of above-mentioned sections for each vulnerability.

iii) <u>Presentation</u>

Members present their contributions for the working applications as well as their findings and analysis from the penetration testing. For the user acceptance test, members will demonstrate that the system meets the functional and non-functional requirements. In addition, tutors will provide additional inputs/actions to test and verify the system. Please prepare the presentation slides discuss the above-mentioned areas in Phase 3.

Deliverables: To be submitted during Final Submission

Deliverables (individual)	Deliverables (group)
1. Demonstration and presentation of Penetration Test results *(20%)* • Juice Shop Application • Major Application	1. Nil
2. User acceptance test based on the use cases and security features and presentation of final product *(20%)*	2. Nil

Date of submission: Please refer to teaching plan

4. Phase 4: Final report *[Group (10%)]*

Complete the remaining sections of the report in terms of

- Introduction
- Any outstanding issues and functions
- Future enhancements
- Conclusion
- Individual Penetration Test results

Deliverables: To be submitted during Final Submission

Deliverables (individual)	Deliverables (group)
1. Nil	1. Complete all the sections in the final report *(10%)* *(See P0xGpx_NAME_SWAP_ReportTemplate.docx)*

Date of submission: Please refer to teaching plan

☑ Assessment

Breakdown of assessment weightages are as follows.

Assessment	**Weightages**	
	Individual	Group
Case Study Project • Proposal & Interim Demonstration • Demonstration, Presentation & Report	 10% 40%	 10% 10%
Total	**50%**	**20%**

Each member will be assessed based on the following:

- Functional and non-functional requirements
- Robustness of the application
- Documentation
- Presentation
- Individual questions and answers

☑ Submission

The final report ***should not exceed 100 pages*** (include pages starting from Introduction to Conclusion). Please include supporting information under an appendix section. Presentation slides and written reports (i.e. proposal/final report) to be submitted via LMS. Please named the reports and slides in the following format:

P0<*CLASS*>Grp<*GROUP*>_<*NAMES*>_SWAP_<*TYPE*>Slides
P0<*CLASS*>Grp<*GROUP*>_<*NAMES*>_SWAP_<*TYPE*>Report

- *<CLASS>* : Class number
- *<GROUP>* : Group Number in the class
- *<NAMES>* : Names of group members
- *<TYPE>* : Proposal or Final

E.g. Class *1*, Group *1* and *Proposal* Report named as
P0*1*Grp*1*_<*StudentNames*>_SWAP_*Proposal*Report

Please note that the standard penalties for late submissions are as follows:

- Late < 1 day: 10% deduction from absolute mark given for the assignment.
- Late ⩾ 1 and < 2 days: 20% deduction from absolute mark.
- Late ⩾ 2 days: No marks awarded.

In addition, plagiarism is an academic offence and disciplinary action will be taken for plagiarism.

--END--